Data Processing Addendum

(Test Fixture – GDPR / DPA)
Title: Data Processing Addendum (DPA) – CloudSignal Analytics Platform
Version: 1.0 (Test Document)
Effective Date: 10 February 2026
Controller: Customer (Orion HealthFin Services GmbH)
Processor: Provider (CloudSignal Technologies Pvt. Ltd.)

1. Definitions

1.1 Terms like **"Controller," "Processor," "Processing," "Personal Data," "Supervisory Authority,"** and **"Data Subject"** have meanings given under GDPR.
1.2 **"Applicable Data Protection Laws"** includes GDPR, UK GDPR (if applicable), and local laws.

2. Scope and Roles

2.1 Customer is the **Controller** of Personal Data. Provider is the **Processor**.
2.2 Provider will process Personal Data only on documented instructions from Customer, unless required by law.

3. Details of Processing

3.1 **Subject matter:** SaaS analytics and reporting platform.
3.2 **Duration:** Subscription Term + deletion/return period.
3.3 **Nature and purpose:** Hosting, analytics, dashboards, alerts, AI summaries (if enabled).
3.4 **Categories of Data Subjects:** Customer employees, end-users, vendors, patients/clients (if uploaded).
3.5 **Categories of Personal Data:** Names, emails, device identifiers, usage logs, transactional data; may include special categories if Customer uploads them.

4. Processor Obligations

4.1 Provider will:

- process only on Customer instructions

- ensure confidentiality commitments for personnel
- implement appropriate security measures
- assist with data subject requests (where applicable)

5. Security Measures (Important Test Section)

5.1 Provider shall implement **appropriate technical and organisational measures** including encryption and access controls.
5.2 **Security Standard (Red-Flag Clause).** Provider may change security measures at any time, and Customer agrees such changes may **reduce** security provided they are "commercially reasonable."

6. Subprocessing

6.1 Customer provides general authorisation for Subprocessors.
6.2 Provider will maintain a list of Subprocessors and provide notice of changes.
6.3 Customer may object to new Subprocessors within 10 days.
6.4 **Subprocessor Liability (Red-Flag Clause).** Provider is not liable for Subprocessor acts once Customer has "general authorisation."

7. International Transfers (Important Test Section)

7.1 Provider may transfer Personal Data outside EEA/UK.
7.2 **Transfer Mechanism (Red-Flag Clause).** Customer agrees that transfers are permitted **without** Standard Contractual Clauses or any other safeguards if Provider determines safeguards are "not required."

8. Assistance to Customer

8.1 Provider will assist Customer with:

- DPIAs "when reasonably required"
- consultation with Supervisory Authorities "at Customer's cost"
- breach notifications as below

9. Personal Data Breach Notification (Important Test Section)

9.1 Provider will notify Customer of a Personal Data Breach **within 10 business days** after becoming aware. *(Red-Flag: GDPR expects "without undue delay"; 10 business days is often too slow for regulated orgs.)*
9.2 Provider will provide information "as available."

10. Deletion and Return (Important Test Section)

10.1 Upon termination, Provider will delete or return Personal Data within **180 days**.
10.2 **Retention (Red-Flag Clause).** Provider may retain Personal Data indefinitely where it is "useful for improving services" or "for internal analytics."

11. Audit and Compliance

11.1 Provider will make information available to demonstrate compliance.
11.2 Customer may audit no more than once every **36 months**. *(Often too restrictive.)*
11.3 Provider may charge audit fees at its "standard rates."

12. Conflicts

12.1 If there is a conflict, the **MSA controls**. *(Red-Flag: DPA should usually override for data protection.)*

13. AI / Automated Decision-Making (Optional but Powerful Test)

13.1 If AI features are enabled, Provider may generate summaries and recommendations.
13.2 **Automated Decisions (Red-Flag Clause).** Customer authorises Provider to make automated decisions that produce legal or similarly significant effects on Data Subjects, without requiring human review.
13.3 Provider may use Personal Data for model training unless Customer opts out in writing.

Annex 1 – Processing Details

- **Services:** Cloud analytics platform, AI summaries (optional)

- **Frequency:** Continuous
- **Retention:** As per Section 10

Annex 2 – Technical and Organisational Measures (TOMs)

- Access control: RBAC
- Encryption in transit: TLS
- Encryption at rest: “supported”
- Logging: application logs
- Incident response: internal playbooks
- Business continuity: backups
  (Intentionally high-level so your agent can flag “insufficient TOM detail.”)

Annex 3 – Subprocessors (Sample)

- Cloud hosting provider (US-based)
- Email delivery provider (EU-based)
- Observability/logging provider (global)